

Unomundi.com Security Engagement Findings

Engagement 2026-05-05 (DPA on file)
2026-05-05

CONFIDENTIAL

CONTENTS

title: "Unomundi.com — Security Engagement Findings" subtitle: "Stakeholder summary" author: "Engagement 2026-05-05" date: "2026-05-05" geometry:

Executive summary	
Findings at a glance	
F-1 — Production Supabase Studio publicly accessible without authentication	
What it is	
Impact	
Remediation	
Reference	
F-2a — pg_stat_statements anonymously readable from public schema	
What it is	
What attacker actually learns	
Why it's still HIGH	
Remediation	
F-2 — Kong gateway exposed on dev-supabase	
What it is	
What anon and authenticated-anon can actually read	
Remediation	
F-3 — Production admin panel built with dev backend URLs	
F-4 — Public OpenAPI spec discloses full API endpoint inventory	
A-1 — Anonymous signup auto-classifies users as guardian	
Other findings (summary)	
Methodology and what was not done	
Engagement state	
Appendices	

title: “Unomundi.com — Security Engagement Findings” subtitle: “Stakeholder summary” author: “Engagement 2026-05-05” date: “2026-05-05” geometry: margin=1in

CONFIDENTIAL

Executive summary

A security engagement was conducted against unomundi.com on 2026-05-05 under a signed scope contract with Data Processing Agreement covering production data including minors' personal data. Three findings require remediation **today**; the rest are itemized below.

The dominant finding: **the production self-hosted Supabase Studio at `https://supabase.unomundi.com` is reachable on the public internet without authentication**. Anyone with the URL can use the Studio Table Editor to read and modify every table in the production database, including children's profiles (`explorer_profiles`), authentication tables (`auth.users` , `auth.sessions` , `explorer_login_otps` , `explorer_pairing_codes`), consent records, and the rest of the application schema. Studio uses an internal service-role key that bypasses every RLS policy, so the row-level controls configured elsewhere in the system do not apply to anyone who reaches Studio's UI.

Production Studio access was confirmed by browser screenshot during the engagement. The operator did not exfiltrate row data from sensitive tables; the access vector was proven structurally and visually, sufficient for impact assessment.

Because the product serves children ages 6-12 and the company is registered in the Netherlands, **GDPR Art. 33 (72-hour breach notification to the Autoriteit Persoonsgegevens) likely applies** as soon as Unomundi has actual knowledge of the exposure. This document is one of several mechanisms by which that knowledge has now been established. The clock should be treated as running from receipt of the disclosure email accompanying this report.

Findings at a glance

ID	Severity	Finding	Action window
F-1	CRITICAL	Production Supabase Studio publicly accessible without authentication	Today
F-2a	HIGH	<code>pg_stat_statements</code> anonymously readable from public schema	Today
F-2	HIGH	Kong gateway on dev-supabase reachable from internet; schema disclosed	Today
F-3	HIGH	Production admin panel built with dev backend URL	This week
F-4	HIGH	Public OpenAPI spec at <code>api.unomundi.com/docs</code>	This week
A-1	MEDIUM	Anonymous signup auto-classifies users as <code>guardian</code> (parent)	This week
F-5	MEDIUM	Dev environments fully internet-reachable	This week
F-6	MEDIUM	Non-standard ports open on backend EC2 hosts	This week
F-12	MEDIUM	Admin panel served without security headers	This sprint
F-7..F-11, F-13..F-15, A-2, A-3	LOW/INFO	Hygiene items	Backlog

F-1 — Production Supabase Studio publicly accessible without authentication

Severity: CRITICAL **Status:** confirmed visually (operator screenshot, 2026-05-05) and structurally (unauthenticated stub-profile response from `/api/platform/profile`)

What it is

Self-hosted Supabase Studio is the administrative web UI normally used by developers and DBAs. It runs as a Next.js application that talks to Postgres via an internal pg-meta service using a Postgres `service_role` key. The service role bypasses every Row-Level Security policy.

When a Studio container is started without `DASHBOARD_USERNAME` and `DASHBOARD_PASSWORD` environment variables and is not placed behind a reverse-proxy authentication layer, **the entire Studio UI is reachable to anyone who knows the URL.**

`https://supabase.unomundi.com/` was reachable without authentication from a clean network. The Studio Table Editor rendered the production `public.explorer_profiles` table with rows containing children's ages, country ISO codes, and explorer UUIDs. The schema sidebar exposed additional sensitive tables not advertised by the public API, including `explorer_login_otps`, `explorer_pairing_codes`, `auth_rate_limits`, and the full `auth.*` schema (`auth.users`, `auth.sessions`).

Impact

- **Read access** to every table in every schema, including `auth.users` (user identifiers and email if email auth was ever used), `auth.sessions` (active session tokens), `explorer_login_otps` (one-time login codes for child accounts), `explorer_pairing_codes` (device pairing), `consent_records`, `explorer_profiles`, `guardian_explorer_relations` (family graph), and behavioural tables.
- **Write access** via Studio's SQL Editor and Table Editor: an attacker can modify or drop any table.
- **Session takeover** is possible: reading active refresh tokens from `auth.sessions` permits impersonation of any logged-in user, including parents and children.
- **Data integrity** is at risk: an attacker can modify consent records, screen-time settings, or guardian-explorer relations.

Remediation

In priority order:

1. **Immediate (≤30 minutes):** put nginx `auth_basic` or Cloudflare Access in front of `*.supabase.unomundi.com`, OR set `DASHBOARD_USERNAME` and `DASHBOARD_PASSWORD` on the Studio container and restart, OR firewall the host until #2 is ready.
2. **Short term (this week):** move Studio off the public internet entirely. Bind it to localhost or to a VPC-internal subnet. Access via SSH tunnel, Tailscale, or Cloudflare WARP.
3. **Audit (parallel):** review Postgres audit logs for the past 30 days for queries originating outside the application's expected sources. Rotate the `service_role` JWT after the audit completes (any reader of the open Studio could have extracted it).
4. **Compliance (parallel):** consult counsel on GDPR Art. 33. Even if no exfiltration is confirmed, the access vector existed and the product handles minors' data.

Reference

Supabase self-hosting documentation explicitly warns that Studio "MUST be protected" when self-hosted:

https://supabase.com/docs/guides/self-hosting/dockerSMARTPANTS_RESERVED_352SMARTPANTS_RESERVED_353

F-2a — `pg_stat_statements` anonymously readable from public schema

Severity: HIGH (information disclosure; no PII leak via this view due to Postgres's built-in role-based privilege check)

What it is

The Postgres extension `pg_stat_statements` records every parameterized SQL statement the database has executed, with execution counts and timing. It is installed in the `public` schema with `SELECT` granted to the `anon` role, which means it is readable by any client through the open Kong gateway at `dev-supabase.unomundi.com:8000`.

Postgres has a built-in protection: the `query` text column is masked as `<insufficient_privilege>` for any statement not owned by the requesting role. Of 3,938 statements in the view at the time of capture, only 87 (2.2%) had visible query text — exclusively queries that ran in `anon` -role sessions.

Parameter values are canonicalized as `$1, $2, $3, ...` (the configuration is `track = top` or equivalent), so **no row-level PII is leaked through this view**.

What attacker actually learns

- Production traffic volume: 10.4 million query executions, 16.8 million rows returned.
- Workload concentration: top 10 statements account for 92% of all calls.
- Internal SQL structure of PostgREST's request-handling wrappers.
- The existence of a custom RPC `is_super_admin()` (we tested: returns `false` to `anon` and authenticated; correct behaviour).
- The fact that the application issues queries against `explorer_profiles` and `profiles` from the `anon` role, relying on RLS to filter results.

Why it's still HIGH

`pg_stat_statements` is a Postgres internals view and should not sit in `public` with `SELECT` granted to public-facing roles. Information disclosure of internal SQL structure makes future findings easier to chain, and the misconfiguration suggests the schema review on this deployment was not thorough.

Remediation

```
REVOKE SELECT ON pg_stat_statements FROM anon, authenticated;
REVOKE SELECT ON pg_stat_statements info FROM anon, authenticated;

CREATE SCHEMA IF NOT EXISTS monitoring;
ALTER EXTENSION pg_stat_statements SET SCHEMA monitoring;
GRANT USAGE ON SCHEMA monitoring TO postgres;
```

Verify `pg_stat_statements.track = top` and `pg_stat_statements.track_utility = off` in `postgresql.conf`.

F-2 — Kong gateway exposed on dev-supabase

Severity: HIGH (RLS holds the line on user-data tables; schema disclosure and signup path are the residual risk)

What it is

Production Supabase's Kong port (:8000) is firewalled, but the dev environment's Kong is reachable from the public internet at <http://dev-supabase.unomundi.com:8000> . This is the gateway in front of all Supabase services: PostgREST (</rest/v1/>), GoTrue (</auth/v1/>), Storage (</storage/v1/>), Functions (</functions/v1/>), and Realtime.

</rest/v1/> returns the full PostgREST OpenAPI specification — 245 KB of Swagger 2.0, 59 tables, 99 endpoints — including the [definitions](#) for tables holding minors' data: [explorer_profiles](#) , [guardian_explorer_relations](#) , [consent_records](#) , [explorer_screen_time](#) * , [analytics_events](#) , [pg_stat_statements](#) .

</auth/v1/settings> reveals that anonymous signup is enabled ([anonymous_users: true](#) , [disable_signup: false](#)), allowing any visitor to register without email verification.

What anon and authenticated-anon can actually read

- Anon role: [pg_stat_statements](#) metadata (3,938 rows; F-2a), [pg_stat_statements_info](#) (1 row), [localizations](#) (3 rows). All other tables RLS-blocked.
- Authenticated-anon role (after one empty-body [POST /auth/v1/signup](#)): 30+ catalogue tables totalling roughly 6,500 rows of educational content (lessons, chapters, quiz questions, gallery images, translations). All children's-data tables remain RLS-blocked.

Remediation

1. Firewall Kong ports [8000](#) and [8443](#) on dev-supabase. They should only be reachable from the application's internal subnet or via a bastion.
2. Set [anonymous_users: false](#) in GoTrue config for both prod and dev unless an explicit product flow requires it.
3. Audit RLS policies on every table in [public](#) ; ensure [enable_RLS](#) is set on each one and policies exist (deny-by-default).

F-3 — Production admin panel built with dev backend URLs

Severity: HIGH

The production admin SPA at `admin.unomundi.com` ships a JavaScript bundle that contains:

```
VITE_BACKEND_URL: "https://dev-supabase.unomundi.com"  
VITE_SUPABASE_URL: "https://dev-supabase.unomundi.com"
```

Either the CI build pipeline is failing to inject production environment variables (and dev values are baked into the prod artifact), or the production admin operates against the dev Supabase backend by design. Either case is a problem: combined with F-1 and F-2, prod admins have been operating against an unauthenticated database with a public Kong gateway.

Remediation: verify the Vite build pipeline injects environment-specific `.env` files for production builds. Confirm prod and dev databases are physically separate. Re-issue Supabase anon JWTs after segregation. Add a build-time guard preventing `VITE_SUPABASE_URL=dev-*` in production artifacts.

F-4 — Public OpenAPI spec discloses full API endpoint inventory

Severity: HIGH

<https://api.unomundi.com/docs> returns a Scalar API Reference page that reveals the full NestJS endpoint inventory: `POST /ai/session` (ElevenLabs voice integration), `GET /ai/conversation-token`, `POST /content-import/lessons` (admin lesson import, x-api-key auth), `GET /video/playback-token/{lessonId}` (signed video URLs), `GET /health`. Authentication on protected paths is correctly enforced (returns 401), but the inventory disclosure accelerates targeted attacks.

The `/ai/session` endpoint is particularly sensitive given the children's voice-AI use case. Any future auth bypass on this path becomes a child-safety incident.

Remediation: restrict `/docs` to internal IPs in production, or remove the route entirely on prod and host the spec elsewhere.

A-1 — Anonymous signup auto-classifies users as guardian

Severity: MEDIUM (raised from informational because of children's-product context)

GoTrue's anonymous-signup endpoint (`POST /auth/v1/signup` with empty body, enabled by `anonymous_users: true`) creates an `auth.users` row, which triggers an auto-provisioning chain that creates `public.profiles` with `role: "guardian"` and `public.guardian_settings` . Any visitor on the internet, with no email verification and no captcha, becomes a "parent" in the application data model.

For a children's-tech product where the guardian role implies adult oversight and Art. 8 GDPR consent, this dilutes the assurance materially. If any consent or guardian-action endpoint trusts `role = 'guardian'` to permit operations on a child account (linking explorer to guardian, granting screen-time, accepting AI terms on the child's behalf) without further verifying `email_confirmed at IS NOT NULL` and `is_anonymous = false` , an anonymous-but-authenticated session can perform those actions.

The Dutch AVG and GDPR-K assume parental consent is given by an identifiable adult. An "anonymous guardian" cannot give meaningful Art. 8 consent.

Remediation:

- Default new profiles to a `pending` role until email-verified or explicitly upgraded.
- Block the anonymous signup path entirely (`anonymous_users: false`) unless a specific product flow needs it.
- If anonymous signup is needed for a try-before-you-buy flow, gate guardian-classified actions on `is_adult = true AND email_confirmed at IS NOT NULL` .

Other findings (summary)

- **F-5** dev environments (`dev-admin` , `dev-api` , `dev-supabase`) fully internet-reachable with valid Let's Encrypt certs. Move behind VPN / Cloudflare Access / IP allowlist; use private CA for dev TLS so dev hosts don't appear in CT logs.
- **F-6** non-standard ports open on backend EC2 hosts (3000, 5000, 5060, 8080, 8443). Lock down EC2 security groups to 80/443 and bastion-only SSH.
- **F-7** `/health` discloses uptime and DB status; make public health a thin liveness ping.
- **F-8** nginx version drift across hosts (1.27.5 vs 1.28.2). Align.
- **F-9** CAA records absent on the apex domain. Add Let's Encrypt issue + `iodef` .
- **F-10** DMARC set to `p=quarantine` . Tighten to `p=reject` after 2 weeks of monitoring.
- **F-11** SSH (22/tcp) reachable on every backend host with AWS EC2 rDNS hostnames disclosed. Bastion or AWS Session Manager.
- **F-12** admin panel served without HSTS / CSP / X-Frame-Options / X-Content-Type-Options / Referrer-Policy / Permissions-Policy and `Content-Encoding: deflate` (BREACH-relevant). Add headers, switch to gzip or br.
- **F-13** API 404 reflects the request path in JSON body. Cosmetic but unnecessary.
- **F-14** `Access-Control-Allow-Origin: *` on `api.unomundi.com`. Restrict to known frontend origins.
- **F-15** rDNS reveals AWS EC2 instance hostnames; informational.
- **A-2** approximately 6,500 rows of educational content readable by any anonymously-registered user (350 lessons, 256 quiz questions, 1,024 quiz answers, 566 gallery images, etc.). Possibly intentional preview, possibly leakage of paid IP. Awaiting confirmation of intent.
- **A-3** custom RPC `is_super_admin()` is publicly callable. Returns `false` correctly to anon and authenticated. No action needed.

Methodology and what was *not* done

The engagement followed standard external pentest methodology: passive OSINT → asset discovery → fingerprint → targeted endpoint probing → vulnerability scan → row-count exposure mapping → bounded data extraction under DPA.

Tools used: nmap, httpx, subfinder, curl, nuclei, nikto, custom Python probes.

Despite the DPA authorising row-level extraction of minors' production data, the engagement applied data-minimisation throughout:

- **No SQL was executed through the open Studio.** Structural proof was sufficient.
- **No row data was read from `explorer_profiles`, `consent_records`, `guardian_explorer_relations`, `analytics_events`, `lesson_progresses`, `screen-time tables`, or any other minors-PII table.**
- The `pg_stat_statements` extraction returned only metadata (counts, timings) and PostgreSQL internal SQL — no parameter values, no PII.
- The catalogue extraction (A-2) read educational content only, not user-generated data.
- One anonymous test account was created (UUID: `9e8efcb3-a753-41dc-9bae-614b70a7dd51`); cleanup SQL is provided.
- All artifacts are stored only on the operator's machine; nothing has been transmitted to third parties.

Engagement state

The engagement is **paused** pending acknowledgement of this report and the accompanying disclosure email. Read-only follow-ups (authenticated-role probes, lateral access checks) remain available if the asset owner wishes to continue after Studio is secured.

Per the DPA: artifacts retained until report acceptance + 30 days, then destroyed via `shred -u`. Storage location: </Users/marcokotrotsos/osint/engagements/unomundi-2026-05-05/>.

CONFIDENTIAL

Appendices

- [findings/findings.md](#) — full technical findings
- [findings/F1-studio-evidence.png](#) — operator-supplied screenshot of open production Studio
- [findings/unomundi-database-schema.md](#) — schema reference (59 tables)
- [findings/authenticated-role-probe.md](#) — authenticated-role analysis
- [findings/A2-content-catalogue-exposure.md](#) — catalogue exposure analysis
- [findings/pgstat-extraction-analysis.md](#) — pg_stat statements analysis
- [findings/count-anon-summary.md](#) — empirical RLS-coverage map
- [findings/disclosure-email.md](#) — disclosure email body
- [out01.md](#) — full educational content catalogue dump (1.5 MB, 6,270 rows; not for customer redistribution)

CONFIDENTIAL